Incident Response Plan

COOKIE-BANNER.CA Document Classification: Internal – Confidential **Effective Date:** 2026-03-28 **Last Reviewed:** 2026-03-28 **Next Review:** 2026-09-28 **Owner:** Founder / Incident Commander **Contact:** security@cookie-banner.ca

---

1. Purpose and Scope

This plan establishes procedures for detecting, responding to, and recovering from security incidents affecting COOKIE-BANNER.CA, a cookie consent management platform (CMP) serving customers under GDPR, PIPEDA, Quebec Law 25, and PECR.

In scope: All production systems, customer data, internal accounts, and third-party integrations including:

- Application layer (Next.js on Vercel)
- Database (Supabase / PostgreSQL)
- Payment processing (Stripe)
- Authentication (NextAuth.js)
- DNS, domain registrar, and email accounts
- Source code repositories

Out of scope: Physical security (fully virtual organization, no offices or data centers). Infrastructure-level incidents at Vercel, Supabase, or Stripe are managed by those providers under their own SOC 2 Type II and PCI DSS programs; however, this plan covers COOKIE-BANNER.CA's response obligations when those incidents affect our customers.

---

2. Incident Classification

Severity	Description	Response Time	Examples
SEV-1 – Critical	Confirmed data breach, active intrusion, or total service outage	Immediate (within 1 hour)	Unauthorized database access, leaked customer PII, compromised auth tokens
SEV-2 – High	Potential breach under investigation, partial outage, or degraded security controls	Within 4 hours	Suspicious login activity, Supabase RLS bypass, payment webhook failures
SEV-3 – Medium	Contained security event, minor service disruption	Within 24 hours	Failed brute-force attempt, single-customer data discrepancy, dependency vulnerability
SEV-4 – Low	Informational, no immediate impact	Within 72 hours	Routine vulnerability scan findings, phishing attempt (unsuccessful), provider advisory

---

3. Roles and Responsibilities

As a solo-founder organization, the Founder serves all incident response roles:

Role	Responsibility
Incident Commander	Owns the incident end-to-end: detection through post-mortem
Technical Responder	Investigates, contains, eradicates, and recovers
Communications Lead	Notifies authorities, affected customers, and providers

Escalation contacts (external, as needed):

- **Legal counsel** – Privacy/data protection attorney (retain on-call relationship)
- **Supabase support** – For database-level incidents
- **Vercel support** – For deployment/infrastructure incidents
- **Stripe support** – For payment data incidents

---

4. Detection and Reporting

Detection Sources

- Vercel deployment logs and function logs
- Supabase dashboard alerts (auth anomalies, query patterns)
- Stripe webhook failure notifications
- Uptime monitoring (external service)
- Customer reports to security@cookie-banner.ca
- GitHub security advisories and Dependabot alerts
- Manual review of access logs

Reporting

Anyone (customers, partners, the founder) who suspects an incident should email **security@cookie-banner.ca** immediately. All incidents are logged in a dedicated incident register with:

- Date/time of detection
- Description and initial severity classification
- Systems and data potentially affected
- Actions taken

---

5. Response Procedures

5.1 Contain

Goal: Stop the incident from spreading.

- Revoke or rotate compromised credentials (Supabase keys, NextAuth secrets, Stripe API keys, Vercel tokens)
- If unauthorized database access is suspected, enable Supabase network restrictions or pause the project
- Revoke active user sessions if auth is compromised
- If a Vercel deployment is compromised, roll back to the last known-good deployment
- Enable maintenance mode if necessary to protect customer data

5.2 Eradicate

Goal: Remove the root cause.

- Identify the attack vector (e.g., compromised dependency, leaked environment variable, social engineering)
- Remove malicious code, unauthorized accounts, or backdoors
- Patch the vulnerability or misconfiguration

- Rotate all credentials that may have been exposed, even if not confirmed compromised
- Update dependencies if a supply-chain vulnerability is involved

5.3 Recover

Goal: Restore normal operations with confidence.

- Deploy verified clean code to Vercel
- Restore database from Supabase point-in-time recovery if data integrity is in question
- Re-enable services incrementally; monitor closely for recurrence
- Verify payment processing is functioning correctly via Stripe dashboard
- Confirm customer-facing banner delivery is operating normally
- Remove maintenance mode

---

6. Evidence Preservation

From the moment an incident is suspected:

- **Do not delete or modify logs.** Export and preserve Vercel function logs, Supabase query logs, and Stripe event logs.
- Take screenshots of dashboards, error messages, and anomalous activity.
- Record all timestamps in UTC.
- Document every action taken during the response, including who did what and when.
- Preserve email headers and full content if phishing or social engineering is involved.
- Store all evidence in a dedicated, access-controlled folder separate from production systems.

Evidence must be retained for a minimum of **5 years** to satisfy regulatory requirements.

---

7. Breach Notification Requirements

7.1 GDPR (EU/EEA Data Subjects)

- Notify the relevant **Supervisory Authority** within **72 hours** of becoming aware of a personal data breach, unless the breach is unlikely to result in a risk to individuals.
- If the breach poses a **high risk** to individuals, notify affected data subjects **without undue delay**.
- Document all breaches in the internal breach register regardless of notification obligation.

7.2 PIPEDA (Canada – Federal)

- Report breaches involving personal information that create a **real risk of significant harm** to the **Office of the Privacy Commissioner of Canada (OPC)** as soon as feasible.
- Notify affected individuals as soon as feasible.
- Notify any third-party organizations that may be able to reduce risk of harm.
- Maintain breach records for **2 years**.

7.3 Quebec Law 25 (Canada – Quebec)

- Notify the **Commission d'acces a l'information du Quebec (CAI)** of any **confidentiality incident** involving personal information that presents a **risk of serious injury**.
- Notify affected individuals as soon as feasible.
- Maintain an incident register and provide it to the CAI upon request.

7.4 PECR / UK GDPR (UK Data Subjects)

- Notify the **Information Commissioner's Office (ICO)** within **72 hours** of becoming aware of a personal data breach that poses a risk to individuals.
- Notify affected individuals without undue delay if the breach poses a high risk.

Notification Checklist

- [ ] Determine which jurisdictions and regulations apply based on affected data subjects
- [ ] Prepare breach description: nature, categories of data, approximate number of records
- [ ] Describe likely consequences and measures taken or proposed
- [ ] File with relevant authorities within required timeframes
- [ ] Notify affected customers with clear, plain-language communication
- [ ] Update the internal breach register

---

8. Communication Plan

Internal

- Log all incident communications with timestamps.
- Use a dedicated incident channel (separate from day-to-day communications) if external contractors or legal counsel are involved.

Customers

- Email affected customers directly from security@cookie-banner.ca.
- Include: what happened, what data was involved, what actions were taken, what customers should do (e.g., rotate API keys), and a contact point for questions.
- If the incident affects banner delivery, post a status update on the public status page.

Authorities

- Use official submission channels for each regulator (see Section 7).
- Retain copies of all submissions and correspondence.

Third-Party Providers

- Notify Supabase, Vercel, or Stripe if the incident involves their systems or requires their cooperation.

---

9. Post-Incident Review

Within **5 business days** of incident resolution, conduct a post-incident review covering:

1. **Timeline** – What happened and when, from detection to resolution.
2. **Root cause** – What allowed the incident to occur.
3. **Response effectiveness** – What went well, what could be improved.
4. **Action items** – Specific, assigned, time-bound improvements (e.g., add monitoring, tighten access controls, update this plan).
5. **Lessons learned** – Document for future reference.

The review is documented in writing and stored alongside the incident record. Action items are tracked to completion.

---

10. Testing and Review Schedule

Activity	Frequency
Review and update this plan	Every 6 months (next: 2026-09-28)
Credential rotation drill	Quarterly
Tabletop walkthrough of a simulated breach scenario	Annually
Review provider incident response capabilities	Annually
Test database point-in-time recovery	Every 6 months
Verify notification contact details for regulators	Every 6 months

---

11. Contact Information

Contact	Details
Incident Commander (Founder)	security@cookie-banner.ca
OPC (Canada)	https://www.priv.gc.ca – 1-800-282-1376
CAI (Quebec)	https://www.cai.gouv.qc.ca
ICO (UK)	https://ico.org.uk – 0303 123 1113
Supabase Support	Via Supabase dashboard
Vercel Support	Via Vercel dashboard
Stripe Support	Via Stripe dashboard

Document History

Version	Date	Change
1.0	2026-03-28	Initial version